University of South Wales
Prifysgol De Cymru

Faculty of Computing, Engineering and Science

Bachelor Project

The Creating of a Lightweight Intrusion Detection System for MQTT-based IoT Networks

Jørn Conradi
23111054

First Supervisor:	Dr. Arun Kumar
Second Supervisor:	Dr. Richard P. Ward
Year of Study:	2025-2026
Course:	BSc Computer Security

University of South Wales
Prifysgol De Cymru

Faculty of Computing, Engineering and Science

STATEMENT OF ORIGINALITY

This is to certify that, except where specific reference is made, the work described in this project is the result of the investigation carried out by the student, and that neither this project nor any part of it has been presented, or is currently being submitted in candidature for any award other than in part for the BSc award, Faculty of Computing, Engineering and Science from the University of South Wales.

Signed .....Jørn Conradi.....
Jørn Conradi

Table of Contents

1 Introduction 8
1.1 Background and Context 8
1.2 Problem Statement 9
1.3 Aim of the Project 10
1.4 Objectives 10
1.5 Significance of the Study 10
1.6 Structure of the Dissertation 11

2 Literature review 12
2.1 IoT Security Landscape 12
2.2 MQTT Protocol Overview & Weaknesses 14
2.3 Intrusion Detection Systems in Network Security 17
2.4 Lightweight Intrusion Detection Systems for IoT 20
2.5 Research Gap and Design Motivation 22
2.6 Chapter Summary 24

3 Methodology 26
3.1 Research Approach 26
3.2 Research Philosophy 26
3.3 Research Design 27
3.4 Data Collection Method 27
3.5 Baseline Training Method 29
3.6 Evaluation Method 29
3.7 Justification of Method Choice 30
3.8 Ethical Considerations 30
3.9 Methodological Limitations 31
3.10 Reliability and Validity 31

4 Design 33
4.1 Design Objectives 33
4.2 System Architecture 34
4.3 Hardware Design 35
4.4 Software Design 37
4.5 IDS Design Logic 37
4.6 Attack Design 39
4.7 Design Rationale 40
4.8 Network Topology of the Testbed 41

5 Evaluation 42
5.1 Introduction to Evaluation 42
5.2 Functional Testing Results 42
5.3 IDS Detection Performance 43
5.4 Lightweight Performance Evaluation 45
5.5 Critical Analysis of Design Strengths and Weaknesses 46
5.6 External Review 47
5.7 Comparison with Literature 48

6 Conclusion 49
7 References 51
8 Appendices 53
8.1 Appendix A - Gantt Chart Project Timeline 53
8.2 Appendix B – External Review 54

Table of Figures

Figure 1 - The MQTT publish – subscribe architecture used in the experimental testbed (author's own diagram). 14
Figure 2 - The network topology shows the interactions between the devices. 41
Figure 3 - The Gantt Chart shows a visualisation of the project schedule. 53

Table 1 - The table shows how well the three detection modes performed. 44

Acknowledgements

I want to thank my supervisors, Arun and Richard for the support, feedback and guidance throughout this project.

I am very grateful for cyber professional Karsten Nyquist, and his external evaluation of my end deliverable. His constructive feedback for my project is very much appreciated.

Thanks to my family who have supported me personally while I have been away and studying abroad.

Abstract

With the fast growth of Internet of Things (IoT) devices has created significant security challenges, especially within networks that use lightweight messaging protocols like Message Queuing Telemetry Transport (MQTT). Traditional intrusion detection systems (IDS) are not suited for IoT environments because they require high resource usage and often lacks awareness of MQTT-specific behaviour. This project takes a look at the feasibility of developing a lightweight IDS that understands MQTT behaviour and is tailored for MQTT-based IoT environments.

A Python-based IDS capable of understanding and monitoring MQTT traffic was created, and a quantitative experimental methodology was used to design and evaluate the Python script. An IoT sensor that generated legitimate traffic and an attacker machine responsible for sending malicious traffic was used together with an MQTT broker, to create a controlled IoT testbed environment. Anomaly-based, signature-based and hybrid IDS rules was used to detect reconnaissance/subscription attempts, oversized payloads, forbidden topic usage, and message flooding attacks. A comparison of the three approaches was then evaluated.

The proposed IDS demonstrated that it was suitable for resource-constrained environments and able to detect malicious traffic from normal MQTT traffic. The evaluation showed that this protocol-aware approach can improve the detection of IoT-specific attacks compared to traditional IDS who doesn't understand MQTT semantics. However, the small-scale testbed and limited attack scenarios are limitations that can be improved in the future.

This project contributes to ongoing research into IoT security and shows the feasibility of creating a lightweight MQTT-aware IDS.

1 Introduction

1.1 Background and Context

The Internet of Things (IoT) continues to grow fast and has become a major part of digital infrastructure in the modern world. Today there are billions of IoT devices worldwide constantly collecting and processing data (Xenofontos et al., 2021).

IoT devices are used in everything from healthcare equipment, industrial monitoring systems, home sensors, and wearable technologies like smartwatches and smart glasses.
The adoption of these devices has helped with automation and enabled efficiency (Tiwari, Pandey and Kokala, 2025).
The fast growth of IoT devices also introduces an increased concern with security. The potential attack surface only increases with the growing number of devices connected, and this means that attackers have even more opportunities to exploit these systems (Zarpelão et al., 2017).

IoT devices are resource constrained and built to be lightweight, low-cost, and energy efficient. Most of these devices are limited when it comes to memory, processing power, and storage capacity. The consequences of these constraints can result in security mechanisms being omitted when the devices are deployed, and most IoT systems also lack mandatory encryption and authentication (Tiwari, Pandey and Kokala, 2025).

One real-world incident, the Mirai botnet, exposed the weaknesses of IoT devices by infecting them and launched denial-of-service (DDoS) attacks in large-scale. (Dinculeană & Cheng, 2019). This example demonstrates how IoT vulnerabilities can impact broader network infrastructure in addition to individual devices.

One of the most popular lightweight messaging protocols for IoT communication is the Message Queuing Telemetry Transport (MQTT). This protocol is specifically designed for resource constrained environments like IoT, and a central broker is where the devices communicate through. MQTT operates on a publish-subscribe model, and it enables minimal bandwidth usage, along with the ability to scale communication between the devices (OASIS, 2014).

The problem with the lightweight design of MQTT is that the majority of real-world deployments do not use Transport Layer Security (TLS), and authentication and encryption is not enforced by default. As a result, attackers can for example subscribe to sensitive topics or publish unauthorised data (Tagliaro et al., 2024).

The monitoring of MQTT-based IoT networks is essential because of these vulnerabilities. Protocol-level attacks may not be detected by preventive protection tools like firewalls, but intrusion detection systems (IDS) are very helpful in this situation. Network traffic and system behaviour is monitored by the IDS and it will alert if it finds any policy violations or malicious activity (Buczak and Guven, 2016).

IDS have three ways of detecting threats: signature-based detection, anomaly-based detection, or a hybrid detection which is a combination of both. Traditional IDS solutions are primarily designed for enterprise networks and often too resource heavy for IoT environments (Zarpelão et al., 2017).

1.2 Problem Statement

There is still a gap between traditional IDS solutions and what the IoT environments require (Zarpelão et al., 2017). Most of the existing IDS tools are not suitable for IoT systems because they are resource-intensive, require large datasets, and they don't focus on IoT-specific protocols but rather general network traffic. This is why it's not suitable to use conventional IDS solutions in IoT networks with limited resources (Butun, Österberg & Song, 2019).

The protocol features in MQTT-based networks, such as publish rates, payload characteristics, and topic structures can be exploited by attackers (Zeghida, Boulaiche & Chikh, 2023). An IDS tool may not detect malicious behaviour if it treats MQTT as normal TCP traffic (Zarpelão et al., 2017). For this reason, an intrusion detection approach that is protocol-aware and lightweight is needed. (Butun, Österberg & Song, 2019).

1.3 Aim of the Project

The aim of this project is to create and evaluate a lightweight intrusion detection system for IoT networks that is MQTT-based. This IDS solution aims to operate effectively in a resource-constrained environment while detecting MQTT-related attacks.

1.4 Objectives

The project will focus on the following objectives in order to achieve this aim:

- ✓ To review existing literature on intrusion detection systems, IoT security, and vulnerabilities of the MQTT protocol.
- ✓ To create a lightweight IDS that is protocol-aware and able to analyse MQTT traffic.
- ✓ To implement the IDS using a custom Python script on a Raspberry Pi testbed.
- ✓ To simulate attacks against the IDS such as oversized payloads, flooding, and unauthorised topic access.
- ✓ To evaluate the effectiveness of the different detection approaches – signature-based, anomaly-based, and hybrid IDS.
- ✓ To compare detection accuracy between the approaches and identify strengths and weaknesses.

1.5 Significance of the Study

By examining IDS designs for small-scale MQTT-based networks, this project contributes to IoT security research. This study evaluates whether lightweight detection techniques can provide effective security, instead of using complex machine learning models. The focus of this study is relevant to real-world IoT environments, where the devices are resource constrained and in need for a lightweight, simple security solution.

1.6 Structure of the Dissertation

This dissertation follows this structure:

- **Chapter 2** reviews the literature on IoT security, IDS, and MQTT vulnerabilities.
- **Chapter 3** describes the methodology of the project.
- **Chapter 4** give details of the system design, implementation, and the experimental testbed.
- **Chapter 5** evaluates the results and discusses the findings and limitations of the IDS.
- **Chapter 6** makes a conclusion for the dissertation.

The full scripts for the IoT testbed is included in the End Deliverable, together with screenshots of the attacks, traffic, logs, and CPU usage.

2 Literature review

2.1 IoT Security Landscape

The Internet of Things (IoT) continues to grow rapidly and billions of IoT devices are currently deployed worldwide. These devices create an interconnected environment where smart appliances, embedded systems, and sensors continuously collect, exchange, and process data. Critical domains such as transportation, healthcare, smart city infrastructures, and industrial control systems are increasingly integrating this IoT technology. Existing research shows that the number of connected devices is only growing, which means the potential attack surface increases for attackers targeting IoT networks (Xenofontos et al., 2021).

One of the main challenges in securing IoT systems comes from the way that these devices are designed. IoT devices are typically designed to be cheap and energy efficient, but this means that they are also limited in battery capacity, memory, and processing power. This is an intentional design and helps lower the manufacturing costs of these devices. The downside of this is that these limitations make it difficult to implement traditional security mechanisms such as multifactor authentication and encryption. These standard security solutions work well on enterprise networks but are too resource-heavy to deploy on low-power IoT environments (Trivedi, Titiya and Bala, 2024).

The lack of robust security controls means that these devices are vulnerable to cyber-attacks. The data transmit of IoT devices are often not encrypted, which makes them vulnerable to data breaches. Another big issue with IoT devices is the lack of standard security protocols, which further complicates security efforts. Not all manufacturers use the same security methods, which means that attackers can exploit these gaps and weaknesses. The rapidly growth of IoT devices and known vulnerabilities makes them attractive targets for attackers (Tiwari, Pandey and Kokala, 2025).

The systemic weaknesses in the IoT environment have resulted in real-world cyber-attacks. The Mirai botnet is a well-known attack that exploited poorly secured IoT devices to launch large-scale DDoS attacks against major infrastructure. This incident highlights how compromised IoT devices can be abused to cause significant disruption beyond their local environment, and scaling into widespread infrastructure-level threats. The Mirai botnet attack illustrates the importance of addressing security weaknesses, not only at the device level but also the network level in IoT environments (Dinculeană and Cheng, 2019).

IoT devices is designed to be resource constrained, and traditional IDS are often not suitable for IoT environments due to its dependence on resource-intensive hardware.
A conventional IDS is often too resource heavy and not suitable for IoT environments. This has led to increased research into network-based intrusion detection systems that are specifically designed for IoT. This approach monitors traffic and protocol behaviour at gateways or nodes without overloading individual IoT devices (Elrawy, Awad and Hamed, 2018).

Overall, the current IoT security landscape reflects fast growth, device limitations, and lack of built-in protection and standardised security protocols. The combination of these conditions creates weaknesses that adversaries can exploit. To protect these IoT networks there is a need for specialised security mechanisms, such as lightweight and protocol-aware IDS that is more tailored for IoT environments.

2.2 MQTT Protocol Overview & Weaknesses

The Message Queuing Telemetry Transport (MQTT) protocol is a lightweight messaging protocol, and it is designed for resource constrained devices such as the Internet of Things (IoT). This protocol was designed to use minimal network bandwidth and system resources, which makes it ideal for devices with limited memory and processing power. According to the OASIS standard, MQTT runs over TCP and uses a publish-subscribe model. The MQTT protocol has become one of the most widely used protocols for communication due to its low overhead and simplicity. (OASIS, 2014)

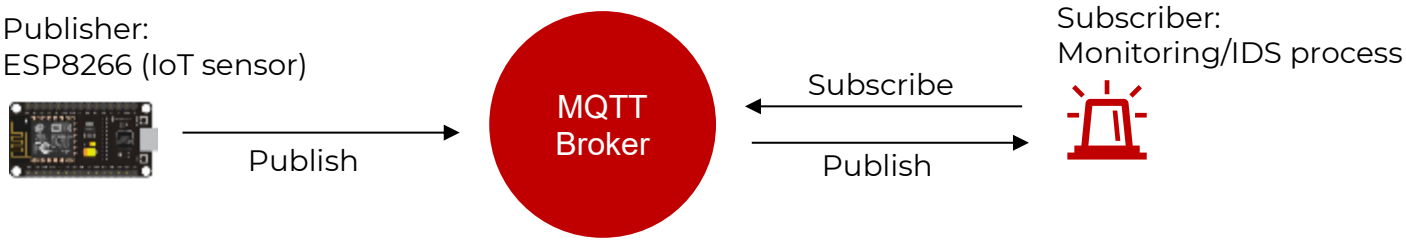

Figure 1 - The MQTT publish – subscribe architecture used in the experimental testbed (author's own diagram).

MQTT uses a publish-subscribe communication model, which means devices don't exchange messages directly. Instead, they send messages through a central server called a broker (figure 1). Devices that send these messages (publishers) label them with topics, and the receiving devices (subscribers) receive messages by subscribing to topics of interest. The broker's responsibility is to receive these published messages and forward them to the clients who are subscribed to the matching topics.

This architecture keeps devices separate from each other which results in improved scalability and reduced network complexity.
MQTT also supports different Quality of Service (QoS) levels which lets applications balance reliability against performance requirements. This design choice explains why MQTT is so popular in constrained IoT environments, but it also limits the security controls available at the protocol level (OASIS, 2019).

However, because this protocol is designed to be lightweight and efficient, security is not built in by default. This is also one of the most significant weaknesses of MQTT, as this protocol does not enforce authentication, authorisation, or encryption (OASIS, 2014). Transport Layer Security (TLS) and strong authentication can be implemented, if not, MQTT messages and login details can be easily intercepted as this traffic is sent in clear text over TCP.

Research has shown that a large amount of MQTT deployments available on the internet do not have encryption enabled, therefore making them vulnerable to common network attacks that can potentially compromise data (Tagliaro et al., 2024).
According to a large-scale study, more than 99% of real-world MQTT services do not run TLS, which greatly increases the risk of data leaks and unauthorised access (Tagliaro et al., 2024).

MQTT's publish-subscribe structure also lacks strong access control built into the protocol. Although brokers may implement access control lists and username/password authentication, these protections are optional and not enforced by the standard. In many real-world implementations access controls are either disabled or use weak credentials.
This means that an attacker can gain access by using default credentials, publish messages to sensitive topics, or subscribe to receive data from IoT devices without permission. Security studies have shown that the lack of this enforcement often leads to attacks involving identity spoofing, privilege abuse, and data manipulation (Hintaw et al., 2023).

Because MQTT is designed to be lightweight, it can be vulnerable to DoS and flooding attacks. An MQTT broker, which is responsible for the message distribution to subscribed clients, can become overwhelmed if it gets flooded with messages.
Prior research has shown that attackers can disrupt MQTT systems by sending malformed messages, spamming subscription requests, and invalid session payloads that causes the broker to crash (Swain, Tripathi and Sethi, 2025).
These weaknesses make it clear that MQTT environments need monitoring to identify abnormal patterns in the traffic that could signal a DoS attack.

The absence of security enforcement within the MQTT standard means that vulnerabilities can also come from how the protocol is implemented. Studies of open-source MQTT brokers and client libraries has shown that some implementations deviate from the protocol specification, and this creates opportunities for exploitation (Di Paolo, Bassetti and Spognardi, 2021).

The combination of these design choices – a publish subscribe model without built-in encryption, optional authentication, and the potential for implementation vulnerabilities – limits the effectiveness of traditional intrusion detection systems. IDS tools may be unable to accurately differentiate between legitimate and malicious MQTT traffic. Because traditional IDS tools do not understand MQTT-specific details like topics, message types, and session state logic. As a result, they may fail to identify abnormal or malicious MQTT traffic unless they are extended with protocol-aware analysis. This limitation has led to growing research interest in specialised IDS approaches that incorporate MQTT-level analysis (Zeghida, Boulaiche and Chikh, 2023).

In summary, the lightweight nature of the MQTT protocol makes it well suited for IoT systems, but its minimal security design creates several risks at the protocol as well as the implementation levels. The risks for DoS attacks and the lack of enforced encryption, authentication, and access control, demonstrate the need for a lightweight IDS that understand MQTT traffic and are tailored for IoT environments.

2.3 Intrusion Detection Systems in Network Security

Intrusion detection systems (IDS) are essential tools used in modern network security architectures, designed to continuously monitor network traffic and system activity. Their main function is to monitor this traffic in order to identify potential attacks or violations of a company's security policies.
In contrast to firewalls, which is a preventive security mechanism, IDS focus on traffic and log analysis, or protocol behaviour to try to detect malicious activity that a firewall may have missed. IDS is an important part of critical infrastructure and organisations due to its ability to monitor and analyse live traffic that may be malicious (Buczak and Guven, 2016).

There are three different IDS approaches described in terms of their detection method: signature-based, anomaly-based, and hybrid IDS.

Signature-based IDS compares network activity against a database of known attack patterns like specific packet sequences. This approach is very effective at detecting threats that have been previously documented, and the false-positive rate is generally low with this solution. The downside with this approach is that it cannot recognise new or unknown attack techniques. Cybercriminals are continually developing new techniques, and this means that signature databases need to be updated regularly. This can be difficult to maintain since the threat landscape is constantly changing (Khraisat et al., 2019).

Anomaly-based IDS functions by establishing a model of normal system or network behaviour and then identifies the deviations from this model as potential attacks. Unlike signature-based detection, this method can detect new or previously unknown threats, which makes it very useful for identifying zero-day attacks. It can be a challenge to define an accurate baseline of normal behaviour, and this approach often produces higher false-positive rates, particularly in environments with variable traffic patterns (Buczak and Guven, 2016).

Hybrid IDS combines both the signature-based and anomaly-based approaches, instead of relying on just one detection method. The hybrid approach aims to achieve accurate detection of known attacks while also using behavioural analysis to identify new or previously unknown attacks. Previous research has demonstrated that hybrid IDS can provide better overall results in terms of detection coverage, especially in complex and diverse network environments (Khraisat et al., 2019).

IDS technologies are widely used in traditional IT networks, but it does not automatically apply to IoT environments. IoT systems involve resource-limited devices, diverse communication protocols, and traffic patterns that are highly dynamic. The majority of IoT devices lack the processing power and memory to support host-based intrusion detection, and it is often not practical to install security software on the endpoint directly.
Because of these limitations, IDS solutions are usually deployed at the network level such as access points, central nodes, or gateways, rather than on the devices themselves (Elrawy, Awad and Hamed, 2018).

Traditional IDS tools are less effective for IoT networks, because these networks require IDS solutions that are specifically tailored to this environment.
Zarpelão et al. (2017) highlight that intrusion detection in IoT environments is challenging due to the wide variety of device types and the limited computational resources. IoT networks also uses lightweight communication protocols which conventional IDS tools does not support by default.
Their survey emphasises the need for a specialised IDS that are designed to detect attacks targeting IoT protocols. Traditional IDS struggle to detect these attacks because they are first and foremost designed for regular TCP/IP networks. This highlights the need for an IDS that are specifically designed to function within an IoT environment (Zarpelão et al., 2017).

Another challenge is the widespread use of application-layer protocols within IoT systems, such as MQTT and CoAP. Traditional IDS solutions focus on analysing transport-layer features such as ports, IP addresses, and packet rates, and often lack the ability to interpret behaviour at the application layer.
Many IoT-related attacks happen at the application layer, with some examples being manipulation of publish-subscribe topics or sending malformed protocol messages. Attacks like this require an understanding of these protocols which conventional IDS tools often lack. As a result, such attacks may go undetected or incorrectly treat normal IoT traffic as malicious (Zarpelão et al., 2017).

One of the challenges of IoT security is the limited resources these devices have, which make it impractical to implement resource-heavy techniques like machine learning models directly on the devices (Butun, Österberg and Song, 2019).
For this reason, most IDS solutions for IoT focus on lightweight detection methods that can detect attacks while reducing computational overhead.
Zarpelão et al. (2017) argue that an effective IoT IDS should balance detection accuracy with resource efficiency, using approaches based on statistical analysis, traffic profiling, and behavioural monitoring. These methods are typically implemented at network gateways or monitoring points rather than the individual devices themselves.

These constraints underline the need for IDS solutions that are protocol-aware, and capable of understanding protocols such as MQTT at the application layer.

Because of these challenges, it has become even more important for research into lightweight network-based IDS solutions for IoT. Instead of securing IoT devices individually, many proposed architectures place IDS functionality that operates at access points or gateways. By monitoring the aggregated traffic from multiple IoT nodes, this centralised approach provides effective intrusion detection without overwhelming constrained endpoints (Elrawy, Awad and Hamed, 2018).

This type of design is particularly relevant to MQTT-based networks, where an access point or single broker serves as a central communication hub.

Overall, these findings highlight the importance of IDS solutions that can identify attacks that bypass traditional security defences. At the same time, the characteristics of IoT environments – resource constrained devices, protocol diversity, and dynamic traffic behaviour – mean that IDS solutions need to be specifically tailored to this domain. Existing research points toward the need for lightweight and protocol-aware IDS approaches that can interpret IoT protocols such as MQTT.
These considerations provide the foundation for the creating of the lightweight IDS proposed in this dissertation.

2.4 Lightweight Intrusion Detection Systems for IoT

Intrusion Detection in IoT environments is very different from traditional IDS as most IoT devices are resource constrained and lightweight in nature. Many IoT devices are unable to run resource-heavy detection mechanisms due to their limited memory and CPU power. For this reason, research has increasingly focused on developing lightweight IDS solutions that provides effective detection while minimising the resource usage (Elrawy, Awad and Hamed, 2018).

When developing a lightweight IDS, a primary strategy involves feature selection and dimensionality reduction. These approaches minimise the volume of data the system needs to process while retaining the most relevant characteristics for detecting malicious activity.
Research in this area indicates that effective feature engineering and the careful selection of representative datasets, can greatly lower computational demands without reducing detection accuracy in resource-constrained environments. By using this approach, The IDS's ability to operate in real time is improved without overwhelming the hardware limitations found in edge devices or IoT gateways (Almalawi, 2025).

Another lightweight IDS solution is based on machine learning models that are designed specifically for resource-constrained devices. While traditional IDS models such as large neural network or support vector machines (SVM) can offer strong detection performance, they usually require a lot of processing power, memory, and training time. In response to this issue, recent research has focused on lightweight machine learning architectures that balance detection accuracy with resource efficiency.
Some examples of these machine learning techniques include decision tree ensembles, shallow classifiers, and small neural networks developed for IoT traffic analysis (Hassan and Zolfy, 2024; Eman et al., 2025).

One of the challenges in intrusion detection for IoT networks is achieving an effective detection accuracy while operating within a resource-constrained environment. To address this issue, researchers have developed IDS frameworks that focus on lightweight design that prioritise advanced feature selection and model optimisation.

For example, Misrak and Melaku (2025) propose a hybrid deep learning approach for IoT environments that uses enhanced feature engineering with dynamic quantisation. This way the model footprint is significantly reduced while maintaining a high detection accuracy. Their model achieves a detection accuracy of 99.73% on benchmark datasets and has a model size of under 32 KB, which makes it ideal for IoT environments. This work demonstrates that enhanced accuracy is possible with advanced feature selection and quantisation in resource-constrained environments (Misrak and Melaku, 2025).

Another lightweight approach focuses on removing unnecessary features through feature pruning and model compression which reduces the model complexity. Explainability-guided pruning and knowledge-distilled models are two machine learning techniques that have been proposed to keep detection accuracy high while significantly reducing inference latency and model size.
IoT applications requires real-time responsiveness and low power consumption, and these optimisations enable IDS deployment on edge devices with limited resources (Benaddi et al., 2025).

Lightweight IDS research for IoT has made strong progress, but there are still several challenges remaining. One example of this is the challenge to balance low resource usage while still maintaining a high detection accuracy. In addition to this, most lightweight IDS proposals are evaluated only on custom datasets or controlled test environments, which raises questions about how well they would perform in real-world IoT environments.
According to Misrak and Melaku (2025), future study should focus on approaches that develop resource-aware and adaptive detection methods that can still work in constrained environments.

In conclusion, reducing computational overhead is the focus of lightweight IDS research.
This is accomplished by using methods such as efficient feature selection, model compression, distributed architectures, and compact machine learning models. Traditional security tools are generally too heavy, so these techniques make sure that intrusion detection is possible in resource-constrained IoT environments.
These methods show that there is an increasing trend toward IDS frameworks that are made specifically for IoT environments.

2.5 Research Gap and Design Motivation

Although there has been a lot of research in the area of IDS for IoT environments, there are still gaps that support the need for a lightweight and protocol-aware IDS for MQTT-based networks. Most traditional IDS solutions were created for enterprise infrastructures, and they often require significant computational resources, therefore making them unsuitable for constrained IoT devices and gateways (Zarpelão et al., 2017). What this highlights is the requirement for IDS approaches that are resource-efficient while not compromising detection accuracy.

To address the challenges of resource constrained IoT environments, research has focused on reducing model complexity by feature engineering, quantization methods, and resource-efficient design. Misrak and Melaku (2025) introduced a lightweight hybrid deep learning model for IoT. This model is tailored for IoT environments because it employs advanced feature selection which removes redundant features. Through dynamic quantization the model size is also reduced while keeping detection accuracy high. This study highlights the challenge of balancing strong detection performance without overwhelming resource constrained devices in real-world IoT systems.

Despite the recent progress, there are challenges remaining regarding the generalisation of lightweight IDS models across different IoT traffic patterns. The research by Misrak and Melaku (2025) point out the need for IDS solutions that are effective and resistant to attack characteristics and real-world traffic diversity. Their observation is that the models trained on benchmark datasets may lose detection accuracy when applied to different, real-world environments, unless further adaption are made.

When it comes to MQTT-based IoT networks, existing IDS approaches often fail to leverage protocol-level semantics such as publish/subscribe behaviours and topic structures. Traditional IDS tools may miss indicators of protocol abuse, like abnormal publish rate or unauthorised topic usage if they analyse MQTT traffic as regular network flows. This gap between conventional IDS tools and protocol-aware detection is pointed out in the IoT intrusion detection literature. The research emphasises the importance of IDS systems that understand MQTT's communication structure at the protocol level (Butun, Österberg and Song, 2019).

The literature also emphasises the advantages and disadvantages of different IDS detection methods. While signature-based rules are good at detecting known attack patterns with low false-positive rates, this approach is limited when it comes to detecting new threats. On the other hand, anomaly-based rules are effective for identifying deviations from normal traffic, but the false-positive rate is higher.

To get the benefits of both approaches, a hybrid IDS framework has been proposed, but this approach can add complexity and higher resource usage.
Together, these findings emphasize the need for IDS designs that can balance simple rules with lightweight anomaly indicators, in order to achieve good detection without being resource heavy (Butun, Österberg and Song, 2019).

Overall, the research gaps discussed justify the development of a lightweight Python-based IDS that is MQTT-aware and can operate efficiently on resource-constrained hardware. Instead of using complex models and deep packet inspection, this proposed approach focuses on traffic metadata and protocol-specific features. By combining signature and anomaly-based rules, the proposed IDS aims to achieve effective detection without overwhelming system resources in small-scale IoT deployments.

2.6 Chapter Summary

In this chapter, the relevant literature on IDS for MQTT-based IoT networks was examined. The discussion started with an overview of the IoT security landscape, where the fast growth of connected IoT devices was emphasised, which leads to a potential increase in attack surface. Common security challenges of IoT were discussed, such as IoT's resource constraints, the lack of built in security, and inconsistent implementation of security standards. These vulnerabilities and the fact that IoT devices is rapidly growing, means that IoT environments are an attractive target for attackers to exploit. This is especially true for compromised IoT devices, because adversaries can use this foothold to perform large-scale attacks beyond their local network.

The chapter then explored the MQTT protocol, focusing on the lightweight publish-subscribe architecture and the security weaknesses that comes from its design. MQTT is well suited for IoT environments which is often constrained. The challenge with this protocol is that it has vulnerabilities such as lack of mandatory encryption, authentication, and access control.
Many of these methods are optional and not enforced by default, which means these vulnerabilities can be exploited through attacks like message flooding, unauthorised topic access, and payload manipulation. The literature demonstrates that these weaknesses in the protocol show how important it is to have security mechanisms that can understand MQTT behaviour, instead of treating MQTT traffic like generic network data.

Next, the chapter reviewed the different IDS approaches – signature-based, anomaly-based, and hybrid IDS. While signature-based IDS demonstrate high accuracy in detecting known threats, it lacks adaptability to new or unknown threats.
Anomaly-based IDS is good at detecting previously unseen attacks, but the false-positive rate is higher, and it is dependent on accurate baseline models. The hybrid IDS approach integrates both these techniques and aim to balance these strengths and weaknesses, but this can introduce additional complexity and become too resource-heavy for constrained IoT environments.

Lightweight IDS for IoT was then explored and the approaches was focused on how feature selection, dimensionality reduction, model optimisation, and protocol-aware detection helps with computational efficiency. Recent research on this has shown promising results, but there are still challenges related to deployment complexity, dataset dependency, and performance in real-world IoT environments. A lot of suggested solutions rely on controlled environments or benchmark dataset, and therefore the effectiveness and generalisability in real-world deployments has been questioned. These limitations demonstrate the gap between existing IDS solutions and the requirements of MQTT-based IoT networks that are small-scale.

These findings in the literature shows that there is a clear research gap between existing IDS solutions and the requirements of MQTT-based IoT networks. This gap is what motivated the development of a lightweight and MQTT-aware IDS that aims to balance computational efficiency with a high detection rate. The methodology chapter builds on this literature review, and it details the design and implementation of the proposed Python-based IDS, including the experimental testbed.

3 Methodology

3.1 Research Approach

The research approach for this dissertation has been conducted using a quantitative experimental research methodology in order to find out the effectiveness of a lightweight IDS for MQTT-based IoT environments. Instead of collecting subjective user opinions, this study evaluates observable network behaviour and controlled attack scenarios. A quantitative experimental approach was chosen because the results are based on measurable data (Creswell, 2014).

When it comes to cybersecurity research, quantitative methods are well suited because they enable measurable indicators like detection rates, false-positive ratios, and system performance to be evaluated objectively (Zarpelão et al., 2017). This project evaluates the IDS performance through analysing network traffic, and it compares how the system responds to legitimate and malicious MQTT activity.

This project involves building a controlled IoT testbed in which both legitimate and malicious traffic could be generated while observing the behaviour of the IDS under repeatable conditions. For this reason, an experimental methodology was adopted. Using this methodology allows the analysis of cause-and-effect relationships, such as how specific attack behaviours influence IDS alerts.

3.2 Research Philosophy

The research methodology for this project follows a positivist philosophy (Saunders, Lewis and Thornhill, 2023). This approach assumes that reality can be observed and measured objectively, in this context network behaviour and security events. Publish rates, topic usage patterns, and message sizes are one of the network features that the IDS operates on. These network features are measurable indicators and makes sure the study is data-driven and objective.

A positivist approach is focusing on observable evidence instead of interpretation and is common in technical and quantitative research (Saunders, Lewis and Thornhill, 2023). Therefore, an objective stance is suitable because the goal of this project is to evaluate the detection capability of the IDS.

3.3 Research Design

The research design consisted of an experimental testbed which was used to simulate a realistic IoT environment. By using this approach, controlled testing of attacks was made possible while repeatable experimentation was maintained.

The testbed for this project consisted of:

- An MQTT broker
- IoT sensor that generated legitimate traffic
- A custom Python script for the IDS
- An attacker machine used for creating malicious traffic

The MQTT traffic was monitored, and alerts were logged by the IDS by using predefined anomaly and signature-based rules.

This design allows normal IoT behaviour, attack scenarios, and IDS detection responses to be compared. The legitimate and malicious traffic can be systematically analysed by using this experimental setup.

Deploying experiments in real-world IoT environments can involve operational, ethical, and legal risks, and therefore controlled testbeds are often used in IoT security research (Butun, Österberg and Song, 2019).

The experiment looks at how the IDS behaves over the different attack scenarios rather than relying on a single test, which makes the results more reliable.

3.4 Data Collection Method

Data was collected by observing the network traffic and through logging of the IDS. The two types of traffic generated were:

Legitimate Traffic

An IoT device (microcontroller) was used to generate legitimate traffic by sending simulated temperature sensor data. This device published messages to the MQTT broker every 30 seconds, and this behaviour enabled the IDS to establish a baseline of normal traffic.
This approach was used because it represents a real-world IoT communication behaviour, which makes the findings more realistic than using simulated datasets.

Malicious Traffic

The malicious traffic was generated from the attacking machine, and these attacks is based on common MQTT threats identified in literature.

The attack scenarios were:

- Oversized payload
- Forbidden topic behaviour
- Message flooding
- Reconnaissance/subscription attempts

This list of attacks targets the weaknesses of the MQTT protocol and can be detected through an IDS that is protocol aware.

IDS Log Collection

The IDS for this project recorded:

- Timestamps of alerts
- Source IP addresses
- Detected anomaly type
- Message characteristics

The traffic patterns of the legitimate traffic were kept consistent to improve reliability. This helped to ensure that the deviations detected during the attack scenarios were due to malicious behaviour rather than random variations.
The logs collected from the IDS formed the dataset for evaluation, and the data logging was automated through the IDS script to help reduce human error.
The automated logging makes sure that the timestamp recording is consistent and eliminates subjective data entry errors.

3.5 Baseline Training Method

A baseline training was established for the anomaly-based detection. During the training period, only legitimate traffic was allowed so the IDS learned what normal traffic looks like:

- Publish frequency
- Payload sizes
- Topic usage patterns

After this training, the IDS used this baseline to detect deviations during the attacks. By using this approach, this method is consistent with anomaly-based IDS approaches discussed in IoT security research (Zarpelão et al., 2017; Butun, Österberg and Song, 2019). It is important to define what "normal" behaviour is so the IDS can detect any activity that deviates from the baseline.

3.6 Evaluation Method

These performance-based metrics was used to evaluate the IDS:

- Detection capability
- False alerts observed
- Responsiveness to attacks
- Ability to distinguish normal vs malicious traffic

These metrics were chosen because they reflect real-world IDS performance. Detection capability shows whether the system is able to identify threats, while false alerts indicate the reliability of the system and are often used in IDS research as a performance metric (Butun, Österberg and Song, 2019).

The usability in real-world deployments can be reduced if there is a high false-positive rate. The consequences of delayed detection can lead to an escalation of the attacks, so responsiveness to attacks is important in IoT environments to prevent threat escalation. Measuring the IDS response timing provides important insights into the effectiveness of the system.

Instead of using large benchmark datasets, this study focuses on feasibility. This supports the approach of a proof-of-concept study. Using live attack scenarios gives more realistic traffic dynamics instead of relying on static datasets.

3.7 Justification of Method Choice

A quantitative experimental method was chosen because it:

- Supports measurable evaluation
- Fits the technical focus of the project
- Enables repeatable experiments
- Reflects real IoT behaviour
- Aligns with research norms for cybersecurity

Qualitative methods such as interviews and surveys were not suitable for this project because the study does not investigate user perceptions, rather the focus is on technical detection performance of an IDS.
The use of simulation-only methods may not accurately reflect real MQTT behaviour, so using a physical IoT device is therefore most suitable for reflecting a real-world IoT environment.

It is possible to use machine learning-based evaluation, but many of these IoT datasets are outdated or they lack specific MQTT traffic. Generating live traffic instead ensured that the data remained relevant to the research problem.

3.8 Ethical Considerations

The experiments conducted for this project were all done in a controlled isolated environment with no external network being affected. All attack scenarios were limited to the access point of the local testbed, which was isolated with no route to the internet. The IoT device used only simulated temperature values that was transmitted to the MQTT broker, and there was no personal or sensitive data being collected.

Ethical cybersecurity research requires that the experiments do not accidentally harm networks or systems. The experimental testbed is inside an isolated environment, so it avoids unauthorised scanning or accidental disruption.
This controlled environment helps ensure the project is conducted responsibly and securely, and in line with ethical cybersecurity research and legal standards.

3.9 Methodological Limitations

There are some limitations of this study:

- Small-scale testbed compared to real-world IoT deployments
- Limited number of attack scenarios
- Observation period is short
- Only one IoT device used

However, the goal for this project is not to get an enterprise-scale validation but rather a proof-of-concept evaluation.

Rather than relying on automated tools, the attack scenarios were manually configured. This is another limitation because automated attack frameworks may produce behaviours that is more varied.
Also, the rules of the IDS were manually created by using a custom Python script. This approach supports transparency, but a machine learning-based system might behave in a different way.

The study focuses on short-term tests and therefore the observation period is short. This approach may not reflect IoT attacks that are occurring over longer periods of time.

Despite the limitations of the methodology, it provides sufficient evidence to evaluate effectiveness and feasibility for the project. The methodology helps to demonstrate the concept of a lightweight IDS that is MQTT-aware.

3.10 Reliability and Validity

Reliability is defined as the consistency of research findings when experiments are repeated under conditions which are similar (Saunders, Lewis and Thornhill, 2023). Automated scripts were used to generate, record and log traffic, and this improves the reliability of the project. The traffic behaviour of the IoT device remained consistent due to the device transmitting data at fixed intervals. The rules of the IDS are fixed and therefore means that repeating the same tests under the same conditions would give similar results.

Validity refers to whether the research measures what it intends to measure (Creswell, 2014). The study of this project focuses on detecting anomalies in the MQTT protocol. Therefore, the experiments were designed around MQTT behaviour such as publish frequency and topic usage. This improves validity of the study and makes sure the evaluation matches the research aim.

One limitation is that the testbed of this project only represents a small-scale IoT environment, and the results may not apply to more complex and large-scale real-world deployments. However, this study still provides evidence about the feasibility and performance of the IDS.

4 Design

4.1 Design Objectives

The main aim of this dissertation is to develop a lightweight IDS that can detect suspicious activity in IoT environments which is MQTT-based, and the end deliverable was designed for this purpose. The current literature review on this topic shows that most of the existing IDS is too resource-heavy, and they are not suitable for IoT deployments which requires a lightweight design (Butun, Österberg and Song, 2019).
Instead of using a machine learning model that require greater computational resources and larger datasets, the findings from the literature review influenced the design of the IDS. This design relies on simple rule-based detection and uses anomaly monitoring which is lightweight.

This is the four main objectives for the design:

- To create a small-scale isolated IoT environment that is capable of generating realistic MQTT traffic
- To generate legitimate traffic using a physical IoT sensor (ESP 8266)
- To use Python to implement protocol-aware IDS logic
- To evaluate detection behaviour during MQTT attack scenarios

Additionally, the design needed to be practical within the project's hardware limitations. The Raspberry Pi platform was chosen as the central component for this reason. The Pi allowed the access point, IDS, and the MQTT broker to run on one lightweight device.

Making sure the IDS directly reflects weaknesses found in MQTT literature was another design objective. The communication of the MQTT protocol consists of a topic-based publish-subscribe model and the design is lightweight. However, this protocol also has weaknesses related to publish behaviour, payload control, and topic handling (Dinculeană and Cheng, 2019).
The MQTT attack scenarios selected was influenced by these weaknesses.

Monitoring MQTT-specific features was the focus of the final design instead of treating the IDS traffic as generic TCP communication.

4.2 System Architecture

The system architecture was designed so that legitimate and malicious traffic could be generated in a safe environment, therefore the wireless IoT testbed was isolated.

These four components made up the architecture:

- Raspberry Pi acting as the MQTT broker, IDS host, and wireless AP
- ESP 8266 microcontroller acting as IoT sensor
- Kali Linux attacker machine that generates malicious traffic
- Wireless adapters that support the device connectivity

The Raspberry Pi hosted the Mosquitto MQTT broker, Python-based IDS script, hostapd wireless access point service, and dnsmasq DHCP service. The Raspberry Pi was the central node of this environment, and by combining these services on one device helped the design to remain lightweight and also reduce infrastructure complexity.

The ESP8266 microcontroller (IoT sensor) was connected to the wireless access point, and every 30 seconds it published simulated temperature values.
By using this behaviour, MQTT publish traffic was created and it enabled the IDS to learn baseline legitimate traffic.

The Kali Linux attack machine was connected to the same wireless AP and generated malicious traffic to the broker. The IDS running on the Raspberry Pi was able to capture and analyse packets from all devices, because all communication passed through the same wireless interface wlan1.

This architecture is representative of realistic MQTT deployment models (OASIS, 2014).

4.3 Hardware Design

This project required a lightweight and realistic small-scale IoT environment, and therefore the following hardware was selected.

Raspberry Pi 5 (8GB RAM)

The Pi was the main platform for the whole system.

The Raspberry Pi hosted:

- Raspberry Pi OS
- Mosquitto MQTT broker
- Python IDS script
- hostapd
- dsnmasq

The choice of using the Raspberry Pi is because it represents a low-cost edge device that is capable of running multiple services, while reflecting an IoT security deployment where hardware is limited.

The literature also justifies this choice because it shows that IoT intrusion detection works well when using a lightweight edge-based monitoring instead of centralised heavy processing (Butun, Österberg and Song, 2019).

Another advantage of the Raspberry Pi is the ability to monitor traffic without additional hardware, because the packet capture could be performed directly on the wireless interface.

ESP8266 Microcontroller (ESP-01S)

The ESP8266 device was used as the legitimate IoT sensor.

The software platform Arduino IDE was used to program the ESP8266 to send simulated temperature values every 30 seconds to the MQTT broker.

The reason for selecting this device is that it reflects realistic IoT constrains:

- Lightweight Wi-Fi communication
- Limited memory
- Low processing power

Constrained devices like the ESP8266 are often using MQTT because it requires minimal bandwidth (OASIS, 2014).

Using a physical sensor enabled the observation of publish intervals and network behaviour and improved realism.

USB to ESP8266 ESP-01S Serial Wireless WiFi Adapter

A USB to ESP8266 Serial WiFi Adapter was used to connect the ESP8266 device to the development environment.

This adapter provided:

- Power delivery during testing
- Stable serial communication
- Firmware upload from Arduino IDE

This adapter was necessary because the IoT sensor (ESP8266) have no integrated USB support.

Atheros AR9271 USB Wi-Fi Adapter

The Atheros Wi-Fi adapter was used to create the wireless access point "IoT_IDS_Lab". This adapter supports monitor mode and packet injection.
This adapter was selected because it is often used in network security environments and provides reliable packet transmission.

Edimax N150 USB Wi-Fi Adapter

The Edimax N150 adapter was used to support wireless connectivity for the Kali VM, and it enabled Kali to successfully connect to the AP.

4.4 Software Design

These software components were used:

- Raspberry Pi OS
- Mosquitto MQTT broker
- Python 3
- PyShark
- Arduino IDE
- JSON configuration file

Mosquitto supports MQTT publish/subscribe communication (OASIS, 2014) and it is commonly used as a lightweight MQTT broker. For this reason, Mosquitto was selected.

Selecting Python for programming allowed for a readable implementation of custom IDS logic.

The development tool Arduino IDE was used to write and upload code to the IoT sensor ESP 8266.

The code for the IDS, JSON configuration file and the IoT sensor was made by generative AI (ChatGPT-4).

PyShark was utilised for live packet capture because it enables packet inspection at the protocol level and it also extract the message fields of MQTT.

4.5 IDS Design Logic

These three operating modes was used for the IDS:

- Signature-based
- Anomaly-based
- Hybrid

This design is supported by the literature which shows that combining deterministic rules with anomaly monitoring helps the system stay flexible while keeping resource use low (Zarpelão et al., 2017).

Signature-based Rules

Signature rules were created for:

- Forbidden topics
- Reconnaissance topic behaviour
- Oversized payloads

The topic structures of MQTT can be abused by attackers to target administrative channels, and therefore forbidden topic rules were included (Hintaw et al., 2023).

The detection of oversized payload was included because abnormal payload may indicate protocol abuse.

Reconnaissance detection was used because attackers frequently test the topic structures before they send further attacks. Therefore, this detection used topic prefixes such as `scan/`.

Anomaly-based Rules

Baseline learning was used for the anomaly-based component, and during baseline training the IDS learned:

- Publish frequency
- Payload size behaviour
- Topic consistency

This is consistent with the principles of anomaly detection. If there are any deviations from this learned normal behaviour it indicates suspicious activity (Zarpelão et al., 2017).

The baseline period consisted of five minutes training to allow the ESP8266 sensor to generate normal traffic, so the IDS could learn what normal traffic looks like.

Hybrid Mode

The hybrid mode enabled both signature-based and anomaly-based methods simultaneously.

This method allowed:

- Known attacks to trigger signature alerts
- Suspicious traffic deviations to trigger anomaly alerts

This design doesn't require machine learning complexity, and it supports broader coverage of threats.

4.6 Attack Design

These attack scenarios were selected because they reflect MQTT weaknesses found in the literature.

These four attacks were implemented:

- Oversized payload attack
- Forbidden topic attack
- Flooding attack
- Reconnaissance/subscription attempts

The attacks align with weaknesses reported in MQTT security research, and the lightweight nature of the protocol can be exploited through abnormal payload handling, topic misuse, and repeated publish requests (Hintaw et al., 2023).

Flooding attacks were also included because repeated publish requests can overload the resources of the broker and cause a disruption of lightweight IoT communication.

4.7 Design Rationale

The findings from the secondary research have strongly influenced the design of this project.

The literature shows that many IoT IDS solutions are too resource heavy for practical deployment, and therefore the decision was made to use lightweight hardware and simple rules (Butun, Österberg and Song, 2019).

Machine learning was intentionally excluded as recent studies on lightweight IDS still depend on external datasets and feature engineering, and this is beyond the practical scope of this project (Misrak and Melaku, 2025).

The use of a physical IoT sensor like the ESP8266 helped to improve realism and ensured that baseline learning was based on actual MQTT traffic instead of synthetic data.

The isolated testbed also aligns with the experimental methodology presented in Chapter 3 by allowing repeatable tests within a safe and isolated environment.

4.8 Network Topology of the Testbed

Figure 2 displays a visual representation of the experimental IoT testbed that was used for the project.

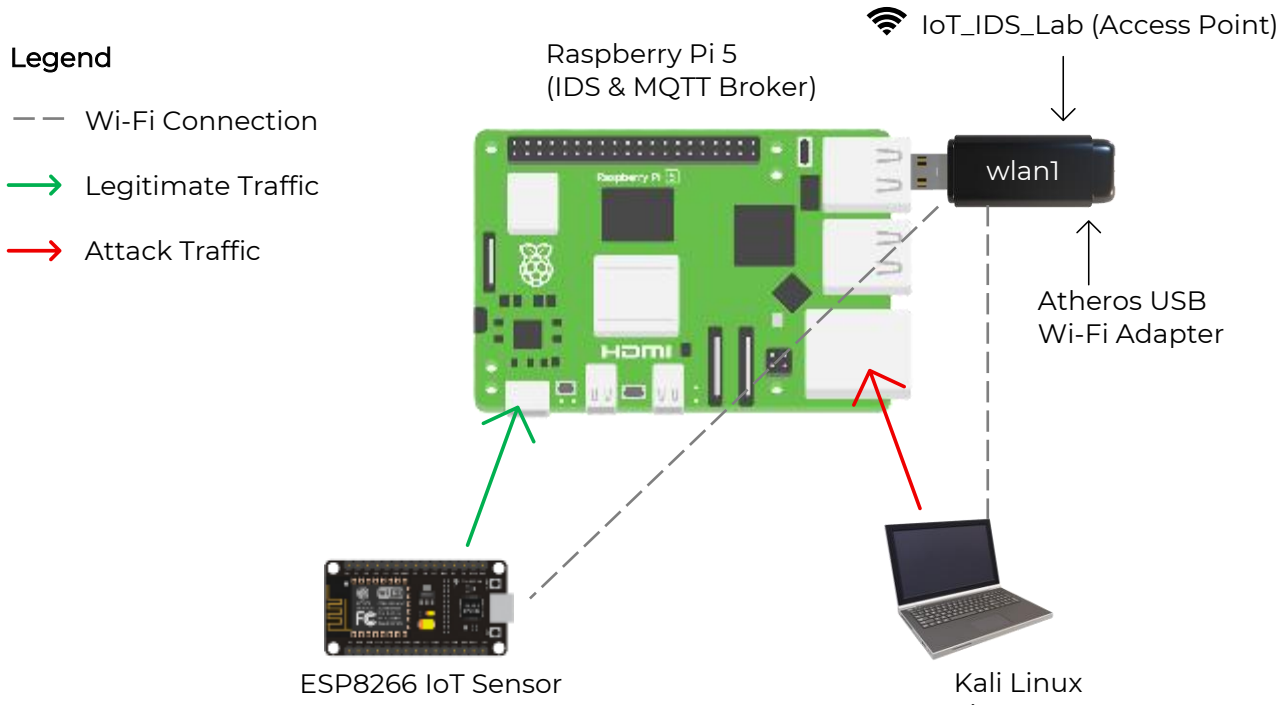

Figure 2 - The network topology shows the interactions between the devices.

5 Evaluation

5.1 Introduction to Evaluation

The goal of this chapter is to evaluate how effective the lightweight IDS made for MQTT-based IoT environments is. The evaluation looks at whether the IDS was able to successfully detect the protocol-specific attacks, how consistently the alerts were firing across the different approaches, and whether the lightweight design was suitable for a constrained IoT environment.

The attack coverage, hardware constraints, and rule sensitivity are some of the practical limitations that were observed during testing and are considered in the evaluation. To improve critical evaluation of the end deliverable, feedback from an external cyber professional is incorporated.

Detection success alone does not indicate practical suitability therefore a critical evaluation is necessary. Also, the reliability, scalability and design limitations of the IDS must be assessed.

5.2 Functional Testing Results

During the controlled attack scenarios, the IDS was tested using three detection modes:

- Signature-based mode
- Anomaly-based mode
- Hybrid mode

The IoT sensor ESP8266 generated legitimate MQTT traffic and published simulated temperature values every 30 seconds, while the Kali Linux attacker machine launched the attacks.

The system remained operational during testing, and during all attack scenarios the packet capture, alert logging, and broker operation continued without interruption. The Mosquitto broker, wireless access point, and IDS was successfully hosted by the Raspberry Pi simultaneously.

The IDS processed MQTT packets in real time from the wireless interface wlan1.

These are the attack scenarios that were tested:

- Oversized payload attack
- Forbidden topic attack
- Flooding behaviour
- Reconnaissance/subscription attempts

For each attack the alerts were triggered based on the corresponding detection rules that was configured in the IDS. Screenshots from the testing is provided in the end deliverable chapter 7 – 9.

5.3 IDS Detection Performance

When it comes to known attack patterns, the signature-based detection performed very well.
The signature-based rules immediately alerted the system when attack traffic matched predefined patterns. This demonstrates that when it comes to identifying known MQTT threats, protocol-specific rule design proves effective.

As shown in table 1, signature-based IDS worked particularly well for:

- Forbidden topics
- Oversized payloads
- Reconnaissance topic names

Predictability is the main strength of signature-based detection.

Signature-based detection relies entirely on predefined conditions, so it is possible that any attack that does not match the predefined existing rules may go undetected.

This is consistent with research in intrusion detection where signature detection shows strong performance for known threats, but struggle against new and unseen attacks like a zero-day attack (Khraisat et al., 2019).

The anomaly-based rules effectively detected deviations from normal publish behaviour after baseline training of the IDS. During the flooding attack, the publish frequency exceeded the learned normal behaviour and this was especially visible (figure 40 in the end deliverable).

During anomaly detection, one limitation observed is that the quality of the baseline directly affects the accuracy of alerts. The baseline was created using only a single IoT sensor, and this only reflects a simple traffic model.
The baseline definition becomes more difficult in larger IoT environments where multiple sensors communicate differently.

This limitation is recognised in anomaly detection literature because more diverse legitimate traffic often increases false positives (Zarpelão et al., 2017).

The hybrid mode provided the best detection coverage because it combined deterministic rule matching (signature rules) together with behavioural deviation checks (anomaly rules).

This supports the findings in intrusion detection literature which shows that hybrid IDS approaches improve coverage in IoT environments without the need for full machine learning complexity (Elrawy, Awad and Hamed, 2018).

Table 1 shows the IDS detection performance after launching the four attacks:

Attack Type	Signature-Based IDS	Anomaly-Based IDS	Hybrid IDS
Oversized Payload	✓	✓	✓
Forbidden Topic	✓	✗	✓
Flooding (High Frequency)	✗	✓	✓
Recon / Sub Attempts	✓	✗	✓

Table 1 - The table shows how well the three detection modes performed.

✓ = Alert generated
✗ = No alert

5.4 Lightweight Performance Evaluation

An important part of the project was to make sure the IDS remained lightweight.

During the testing, the CPU was monitored and this showed that the Raspberry Pi used very little processing power even while attack detection and packet capture were active.

This result indicates that the IDS uses limited resources and is lightweight.

Several design choices explain the lightweight performance of the IDS:

- No machine learning model
- Simple rule evaluation
- Basic statistical anomaly checks

This implementation relies only on direct comparisons, unlike lightweight machine learning IDS approaches that requires feature engineering (Misrak and Melaku, 2025). This helps to reduce the complexity significantly.

One limitation with the lightweight design is that packet capture relies on PyShark. PyShark depends on tshark which means there are some external processing overhead.

There was no performance issues detected in this small-scale testing. However, the CPU usage could increase if the traffic volume is larger.

The lightweight performance demonstrated here should be regarded as a proof-of-concept rather than definitive evidence of scalability.

5.5 Critical Analysis of Design Strengths and Weaknesses

One of the main strengths of the IDS is that it analyses MQTT protocol features directly. Most traditional IDS systems only analyse generic network traffic and is not protocol aware.

The IDS of this project evaluates:

- Topic usage
- Publish intervals
- Payload size

Because MQTT vulnerabilities often emerge through topic misuse or broker interaction patterns, this protocol awareness of the IDS is very relevant (Hintaw et al., 2023).

The design choice of using a physical IoT sensor is another strength. The use of the ESP8266 allowed for direct observation of MQTT communication and publish timing, and this helped to improve realism. This also strengthens validity when compared with studies that only rely on datasets.

However, there are also several limitations of the design of this project.
The testbed consists of only one IoT sensor which means that there is low traffic diversity.

A real-world IoT deployment commonly consist of:

- Multiple devices
- Mixed topics (for example, receiving temperature data from multiple sources)
- Variable publish rates
- Different payload behaviour

The IDS rules are manually created which means the scalability is limited.
For every new threat a manual extension of the rules is required.

This contrasts with adaptive systems, which automatically learn new patterns.

Another limitation is that encrypted MQTT traffic is not included in this project and therefore not evaluated.

Packet inspection may become more challenging when TLS is enabled, if not the broker-side metadata is accessible.

5.6 External Review

To help strengthen the evaluation, the end deliverable was reviewed externally by a cyber professional working as a security analyst/incident responder.
The full external review is included in Appendix B.

The reviewer was asked to evaluate:

- The architecture and concept of the project
- Detection logic
- Suitability for practical deployment and scalability
- Any limitations of the implementation
- Improvements of the project
- Comparison with Suricata

The external reviewer noted that the architecture of a lightweight protocol-aware IDS for MQTT is suitable for IoT security. This is because IoT devices are often compromised and used in botnet-based attacks.

The reviewer confirmed that the detection rules such as publish rate, payload size, topic misuse, and flooding reflect IoT attack behaviour. The reviewer highlighted that the detection coverage is strengthened by using both signature-based and anomaly-based rules.

This assessment aligns with the internal testing of this project where hybrid mode provided the best detection coverage.

The reviewer noted that the main weakness of the IDS was the limited rule set, because it requires much larger attack coverage in today's environment. IDS platforms such as Suricata and Snort helps larger environments to process higher traffic volumes efficiently.

The lightweight IDS performed effectively in a small, isolated environment, but according to the reviewer it requires a bigger ruleset for larger environments.

When it comes to future improvements the reviewer suggested there should be support for easier rule expansion and broader traffic visibility across devices. The current testbed only has one IoT sensor, so this recommendation is very relevant.

In comparison to Suricata, the reviewer stated that the IDS rule structure resembles that of Suricata, but Suricata has broader rule coverage and community support.

This is an important comparison because it shows that the project follows basic IDS design principles.

The external review supports the idea that this project is sufficient as a proof-of-concept lightweight detection system, but it requires a bigger ruleset, broader traffic visibility, and architectural scaling before being deployed in bigger environments.

5.7 Comparison with Literature

The result of this project aligns with what have been identified in the literature.

According to Butun, Österberg, and Song (2019), lightweight intrusion detection requires a low resource usage while still having a sufficient accuracy detection. This project supports this principle by the low CPU observations during testing.

The lightweight IDS study by Misrak and Melaku (2025) are based on machine learning. In contrast, this project sacrifices this adaptive capability for simplicity.

The findings also support those of Dinculeană and Cheng (2019). Their study highlights that MQTT vulnerabilities often comes from protocol simplicity instead of protocol complexity.

This project has successfully detected MQTT vulnerabilities such as payload abuse and topic misuse, and this confirms the effectiveness of protocol-aware monitoring.

6 Conclusion

The goal of this project was to create and evaluate a lightweight IDS that is capable of detecting attacks and suspicious activity within a MQTT-based IoT environment.
The MQTT communication protocol is lightweight and widely used, but it has vulnerabilities that can be exploited. What this project focused on was the creation of a proof-of-concept system that could detect common attacks against the MQTT protocol, while still being lightweight and suitable for an IoT environment.

Overall, the main aim of the project has been successfully achieved. A controlled IoT testbed was created by using a Raspberry Pi as the MQTT broker, ESP8266 sensor to generate legitimate traffic, and Kali Linux to generate attack traffic. A lightweight IDS was implemented on the Raspberry Pi by using a Python script. The IDS was designed to be protocol-aware so it could understand and detect MQTT packet behaviour.

The first objective of the project was to research the vulnerabilities of the MQTT protocol and to find the attack behaviours that is relevant to this protocol.
This objective was achieved through the findings in the literature review which explained that the simplicity of the MQTT protocol creates security weaknesses. This specifically relates to payload abuse, flooding behaviour, and topic misuse, and these findings influenced the attack scenarios used for testing the IDS.

The second objective was to design an isolated IoT testbed that could produce realistic MQTT traffic, and this objective was achieved through the experimental testbed. The Raspberry Pi acted as the MQTT broker, wireless AP, and hosted the IDS. Every 30 seconds, the IoT sensor generated temperature values to the broker, and this traffic reflects legitimate MQTT traffic.

The third objective was to create a lightweight detection logic that could identify suspicious MQTT behaviour. The implementation of the three IDS modes helped to achieve this objective: signature-based detection, anomaly-based detection, and hybrid detection.
The signature rules successfully detected forbidden topic use and oversized payloads, which was the predefined attacks. After baseline training, the anomaly rules identified deviations in publish behaviour. The hybrid mode combined both these approaches and therefore produced the best detection coverage.

The fourth objective was to find out how effective the IDS was through controlled attack scenarios. The CPU monitoring showed that the IDS remained lightweight during the testing and supports the goal of a lightweight design.

The objective of this project has been successfully achieved, however the evaluation showed that there were limitations. Firstly, the IDS was tested in a small-scale environment, and there was only one IoT sensor used. In larger IoT environments there is often more traffic diversity and more complex traffic patterns, and this could make detection less reliable.

A second limitation is that the rule set of the IDS is manually defined. According to the external review, there is a need for more detection rules to get a more broader attack coverage and to identify post-compromise behaviour.

Scalability is another limitation. PyShark is used for packet capture on the Raspberry Pi, which is suitable for a small environment, but higher traffic volumes may affect the performance.

The feedback from the external professional review confirmed that the project is valid as a proof-of-concept, but it needs an architectural change for it to be deployed directly in larger environments.

Future improvements of this project would be to include multiple IoT devices and enable the IDS to monitor these simultaneously to improve the baseline realism. Another improvement would be to extend the rule set to make outbound traffic monitoring and post-compromise behaviour possible. Analysis of encrypted MQTT traffic could also be included in future work.

In summary, the project demonstrates that lightweight intrusion detection that is MQTT-aware is possible within a resource-constrained environment. It showed that this protocol-specific design provides a good detection coverage without the need of a resource-intensive environment. The project provides a practical proof-of-concept model that can help with future development of lightweight IoT IDS methods.

7 References

Abdul Hassan, H.A. and Zolfy, M. (2024). Exploring Lightweight Deep Learning Techniques for Intrusion Detection Systems in IoT Networks: a Survey. *Journal of Electrical Systems*, 20(4s), pp.1944–1958.
doi: https://doi.org/10.52783/jes.2292.

Almalawi, A. (2025). A Lightweight Intrusion Detection System for Internet of Things: Clustering and Monte Carlo Cross-Entropy Approach. *Sensors*, 25(7), pp.2235–2235.
doi: https://doi.org/10.3390/s25072235.

Benaddi, H., Jouhari, M., Laamech, N., Motii, A. and Ibrahimi, K. (2025). Lightweight Intrusion Detection in IoT via SHAP-Guided Feature Pruning and Knowledge-Distilled Kronecker Networks. In: *8th International Conference on Advanced Communication Technologies and Networking*. [online]
doi: https://doi.org/10.1109/CommNet68224.2025.11288887.

Buczak, A.L. and Guven, E. (2016). A Survey of Data Mining and Machine Learning Methods for Cyber Security Intrusion Detection. *IEEE Communications Surveys & Tutorials*, [online] 18(2), pp.1153–1176.
doi: https://doi.org/10.1109/comst.2015.2494502.

Butun, I., Österberg, P. and Song, H. (2019). Security of the Internet of Things: Vulnerabilities, Attacks and Countermeasures. *IEEE Communications Surveys & Tutorials*, [online] 22(1), pp.1–1.
doi: https://doi.org/10.1109/comst.2019.2953364.

Creswell, J.W., 2014. *Research Design: Qualitative, Quantitative, and Mixed Methods Approaches*. 4th ed. Thousand Oaks: SAGE Publications.

Dinculeană, D. and Cheng, X. (2019). Vulnerabilities and Limitations of MQTT Protocol Used between IoT Devices. *Applied Sciences*, [online] 9(5), p.848.
doi: https://doi.org/10.3390/app9050848.

Di Paolo, E., Bassetti, E. and Spognardi, A. (2021). *Security Assessment of Common Open Source MQTT Brokers and Clients*. [online] ITASEC21: Italian Conference on Cybersecurity, April 07–09, 2021.
doi: https://doi.org/10.48550/arXiv.2309.03547

Elrawy, M., Awad, A. and Hamed, H. (2018). Intrusion Detection Systems for IoT-based Smart environments: a Survey. *Journal of Cloud Computing*, [online] 7(1).
doi: https://doi.org/10.1186/s13677-018-0123-6.

Eman, A., Laghari, S.A., Ahmed, N., Hassan, F. and Memon, B.Q. (2025). Machine Learning Based Intrusion Detection System for Iot Networks Utilizing Lightweight Protocols MQTT and CoAP. *Zenodo*, [online] 3(3).
doi: https://doi.org/10.5281/zenodo.15007653.

Hintaw, A.J., Manickam, S., Aboalmaaly, M.F. and Karuppayah, S. (2023). MQTT Vulnerabilities, Attack Vectors and Solutions in the Internet of Things (IoT). *IETE Journal of Research*, 69(6), pp.3368–3397.
doi: https://doi.org/10.1080/03772063.2021.1912651.

Khraisat, A., Gondal, I., Vamplew, P. and Kamruzzaman, J. (2019). Survey of Intrusion Detection systems: techniques, Datasets and Challenges. *Cybersecurity*, [online] 2(1), pp.1–22.
doi: https://doi.org/10.1186/s42400-019-0038-7.

Misrak, S.F. and Melaku, H.M. (2025). Lightweight Intrusion Detection System for IoT with Improved Feature Engineering and Advanced Dynamic Quantization. *Discover Internet of Things*, 5(1).
doi: https://doi.org/10.1007/s43926-025-00203-8.

OASIS (2014). *MQTT v3.1.1*. [online] OASIS Open. Available at: https://www.oasis-open.org/standard/mqttv3-1-1/ [Accessed 28 Dec. 2025].

OASIS (2019). *MQTT Version 5.0*. [online] OASIS Open. Available at: https://www.oasis-open.org/standard/mqtt-v5-0-os/ [Accessed 1 Jan. 2026].

Saunders, M., Lewis, P. and Thornhill, A. (2023). *Research Methods for Business Students*. 9th ed. Pearson.

Swain, M., Tripathi, N. and Sethi, K. (2025). Identifying Communication Sequence Anomalies to Detect DoS Attacks against MQTT. *Computers & Security*, 157.
doi: https://doi.org/10.1016/j.cose.2025.104526.

Tagliaro, C., Komsic, M., Continella, A., Borgolte, K. and Lindorfer, M. (2024). Large-Scale Security Analysis of Real-World Backend Deployments Speaking IoT-Focused Protocols. In: *RAID '24: Proceedings of the 27th International Symposium on Research in Attacks, Intrusions and Defenses*. [online] pp.561–578.
doi: https://doi.org/10.1145/3678890.3678899.

Tiwari, N., Pandey, A.K. and Kokala, A. (2025). Challenges and Solutions for Countering Emerging Security Threats to IoT Devices. *International Journal of Experimental Research and Review*, 47, pp.59–68.
doi: https://doi.org/10.52756/ijerr.2025.v47.005.

Trivedi, M., Titiya, M. and Bala, A. (2024). Secure an Iot Environment from Security Issues and Attacks Using a Secure MQTT Protocol. *Computer Fraud and Security*, 2024(8), pp.286–294.
doi: https://doi.org/10.52710/cfs.749.

Xenofontos, C., Zografopoulos, I., Konstantinou, C., Jolfaei, A., Khan, M.K. and Choo, K.-K.R. (2021). Consumer, Commercial and Industrial IoT (In)Security: Attack Taxonomy and Case Studies. *arXiv.org*. [online]
doi: https://doi.org/10.48550/arXiv.2105.06612.

Zarpelão, B.B., Miani, R.S., Kawakani, C.T. and de Alvarenga, S.C. (2017). A Survey of Intrusion Detection in Internet of Things. *Journal of Network and Computer Applications*, [online] 84, pp.25–37.
doi: https://doi.org/10.1016/j.jnca.2017.02.009.

Zeghida, H., Boulaiche, M. and Chikh, R. (2023). Securing MQTT Protocol for IoT Environment Using IDS Based on Ensemble Learning. In: *International Journal of Information Security*. TACC'2024, the 4th Tunisian-Algerian Conference on Applied Computing. Springer Science+Business Media, pp.1075–1086.
doi: https://doi.org/10.1007/s10207-023-00681-3.

8 Appendices

8.1 Appendix A - Gantt Chart Project Timeline

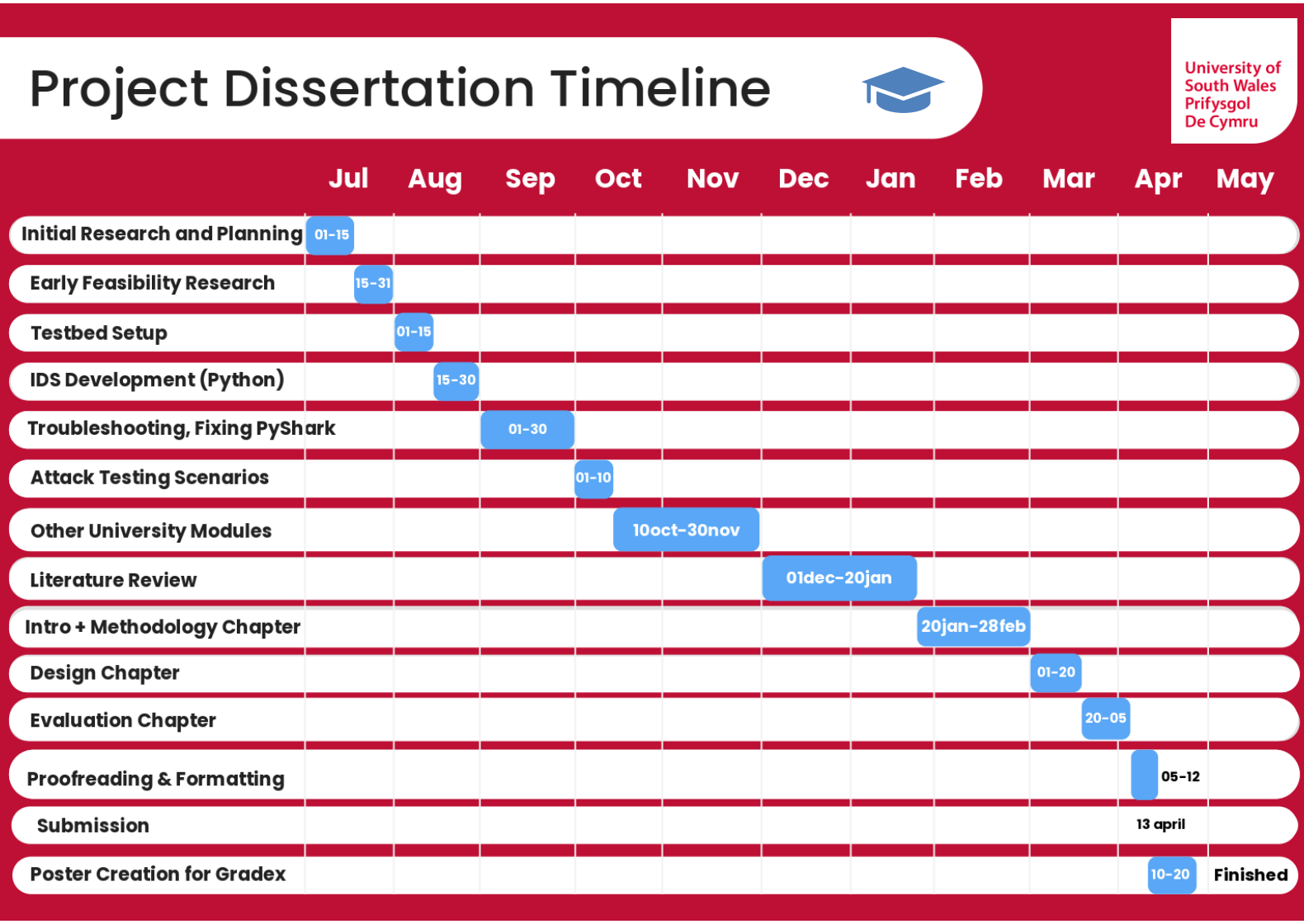

Figure 3 - The Gantt Chart shows a visualisation of the project schedule.

8.2 Appendix B – External Review

The following is a review conducted by cyber professional Karsten Nyquist. Karsten works as an incident responder/security analyst at Mnemonic, Oslo.
Date: 6 April 2026.

---

1 Architecture & Concept

Q1: Do you think the overall design of a lightweight, protocol-aware IDS for MQTT makes sense from a security perspective?

A1: From my perspective, as an incident responder and a security analyst, I think it makes a lot of sense. IoT devices are often attacked and compromised, to later be used in, for example, botnets to launch DDoS attacks.

---

2 Detection Logic

Q2: Do the selected detection rules (publish rate, payload size, topic misuse, flooding) reflect realistic attacker behaviour in IoT environments?

A2: Yes, these reflects realistic attacks against and within IoT environments. With both signature and anomaly-based detections, it strengthens the detection coverage. For future projects, it might be worth creating detections for post-compromise behaviour, to see if the infected devices are used in further attacks. Compromised IoT devices are often used in botnets to send spam campaigns and DDoS attacks. Attackers may also download software needed for such usage.

---

3 Practical Deployment

Q3: In your opinion, would this type of lightweight IDS be feasible in a small or resource-constrained IoT network?

A3: In a small environment, this would be a good base for an IDS.

---

4 Limitations

Q4: What do you see as the biggest weaknesses or limitations of this approach?

A4: One of the biggest weaknesses is the rule set, there need to be much more coverage to cover attacks against and from the IoT devices. In today's environments, we often see packet brokers and other devices that can decrypt traffic and send it in for analysis, often running Suricata and/or Snort on the traffic. For this to scale it also needs something like this, so the lightweight design doesn't get too big.

---

5 Scalability

Q5: Do you think this approach would scale to larger IoT deployments, or would changes be necessary?

A5: Changes would need to be made for this to work in bigger environments. The ruleset needs to be bigger and may need to be open for community support.

---

6 Improvement Suggestions

Q6: If this were to be developed further, what improvements would you recommend?

A6: The sensor needs to be able to listen to a lot of traffic, from different devices. Often such taps sit near the main network device to listen to everything before the packets leave the network, or right as it enters.
There needs to be more rules, and easy to implement these, as attacks evolves at a fast pace.
But as a project/proof-of-concept, this is enough.

---

7 Suricata Comparison

Q7: How does this compare to tools like Suricata in practical environments?

A7: The structure of the rules reminds me a lot of Suricata. If this thesis evolves and incorporates some of the improvements, I think this could be comparable to Suricata. Suricata has a big community, which is part of why it works so well, so it's hard to compare the two.